



Universidad de Jaén

Auditoría y Seguridad en Sistemas de Información

Módulo 2: Sesión 5

Controles y Plan de Acción

Introducción

En este módulo vamos a realizar diversas prácticas para simular una auditoría de manera realista. Las prácticas pueden realizarse en grupos (recomiendo utilizar los mismos grupos de la parte teórica). Dado que no contamos con una empresa en la que realizar la auditoría, vamos a auditar una pequeña empresa virtual.

Objetivo

- Propuesta de controles
- Resultado de los controles
- Plan de acción que contenga recomendaciones para evitar o mitigar las amenazas identificadas de mayor importancia.

Entrega

- Se entregará en cada sesión una **memoria** de trabajo con **formato PDF** donde se incluirá el contenido de las sesiones anteriores.
- Todas las memorias deben incluir una portada con los datos de todos los miembros del equipo.
- Con esta sesión cerramos el contenido práctico del tema 2. Para la evaluación de esta práctica realizada en grupo, se entregará en Platea un archivo pdf con el informe final de la auditoría (debe contener todos apartados vistos en las sesiones anteriores) junto a la presentación que se realizará en clase en la fecha indicada por el profesor.

Descripción

En esta sesión nos centraremos en **establecer controles** para tratar las amenazas y los riesgos de la organización. En el caso de que un control pueda aplicarse a varias amenazas, indicar a cuáles afecta. Por ejemplo, el control titulado "Verificación del software antivirus", se utilizará para detectar amenazas o riesgos del tipo: infección por virus, suplantación de identidad, robo de información, spyware, troyanos, etc.

Vamos a considerar que solo son obligatorios los **controles para las amenazas con una valoración del riesgo igual o superior a 5** (el resto son optativos).

Para cada control, describiremos los siguientes ítems:

- Título del control
- Descripción del riesgo
- Responsable
- Amenazas que cubre
- Resultado de la evaluación
- Plan de acción.

Ejemplo orientativo:

Título Control	[#CO_01]: Cursos de formación.
Descripción	Se llevará a cabo un proceso de inspección para verificar si se organizan e imparten cursos informativos sobre el uso de las tecnologías, normativas de seguridad vigente y otros aspectos relacionados a las buenas prácticas de la empresa.
Responsable	Administrativo - Encargado de recursos humanos.
Amenazas que cubre	• [#A_E07]. • [#A_E05]. • [#A_E13]. • [#A_A16].
Resultado de la evaluación	Los cursos que actualmente se imparten presentan deficiencias: los contenidos están desactualizados, su nivel de profundidad es insuficiente y se realizan con baja frecuencia.
Plan de acción	• Contratar a empresas especializadas en seguridad informática para impartir formaciones continuas y actualizadas. • Actualizar los materiales de formación existentes aprovechando la experiencia de los proveedores contratados. • Implementar encuestas de satisfacción al finalizar cada curso para evaluar su utilidad y detectar áreas de mejora. • Establecer una periodicidad mínima para la formación obligatoria del personal.

Como guía, puedes utilizar la siguiente lista de elementos a controlar organizados por dominios y objetivos de control:

<https://www.iso27000.es/assets/files/ControlesISO27002-2013.pdf>

<https://www.iso27000.es/iso27002.html>



Universidad de Jaén

Auditoría y Seguridad en Sistemas de Información

Módulo 2: Sesión 4

Análisis y Gestión de Riesgos

Introducción

En este módulo vamos a realizar diferentes prácticas que nos permitan simular una auditoría de forma realista. Las prácticas pueden realizarse en grupos (recomiendo utilizar los mismos grupos de la parte teórica). Dado que no tenemos a nuestra disposición una empresa donde realizar la auditoría, vamos a auditar una pequeña empresa virtual.

Objetivo

- Realizar un análisis de riesgos utilizando una tabla de riesgo intrínseco.
- Cuantificar el riesgo de cada amenaza e indicar cómo se va a tratar.

Entrega

- Se entregará en cada sesión una **memoria** de trabajo en formato PDF que incluirá el contenido de las sesiones anteriores.
- Todas las memorias deben incluir una portada con los datos de todos los miembros del equipo.

Descripción

En esta práctica partiremos de los datos de la empresa de las sesiones anteriores así como en los activos y amenazas identificados en la última práctica. En esta sesión nos centraremos en **valorar el impacto** sobre el SI.



Para cada pareja activo-amenaza, llevaremos a cabo las siguientes tareas:

1. **Valoración de activos.** Usaremos una valoración cuantitativa con una escala de 0 a 4 según la importancia de su pérdida y/o reposición para la organización, siendo 4 la mayor valoración posible (p. ej., podemos considerar que los servidores son muy importantes y por lo tanto, les asignaremos un valor de 4).
2. **Valoración del riesgo.** Usando la matriz de riesgo mostrada en la figura 1, calcular el riesgo de cada activo.
3. **Ordenar los activos_amenazas de acuerdo al valor del riesgo intrínseco, de mayor a menor.** Ordenar la dupla activo_amenaza según el valor del riesgo intrínseco calculado. Para ello, se valorará cada amenaza teniendo en consideración la probabilidad de que ocurra la amenaza, el nivel de vulnerabilidad del activo ante dicha amenaza y el valor del activo al que afecta utilizando la siguiente tabla:

Probabilidad de ocurrencia Nivel Vulnerabilidad		Bajo			Medio			Alto		
		B	M	A	B	M	A	B	M	A
VALOR ACTIVO	0	0	1	2	1	2	3	2	3	4
	1	1	2	3	2	3	4	3	4	5
	2	2	3	4	3	4	5	4	5	6
	3	3	4	5	4	5	6	5	6	7
	4	4	5	6	5	6	7	6	7	8

Figura 1 Matriz de riesgo

Nota: Si se han detectado salvaguardas, es necesario tenerlas en cuenta al ajustar el nivel de vulnerabilidad.

4. A partir de la lista ordenada y comenzando por aquellos riesgos con mayor puntuación, vamos a decidir cómo se va a tratar cada riesgo. Habrá que decidir si el riesgo se va a:
 - **Aceptar** que puede ocurrir previendo recursos y acciones si ocurriese.
 - **Prevenir**, reduciendo la probabilidad de que se produzca el riesgo.
 - **Mitigar**, acontando las consecuencias y efectos negativos que puedan producirse.

- **Transferir**, compartirlo con otra organización que se encargue de su control (por ejemplo contratando un servicio o un seguro de cobertura)
- **Evitar** las circunstancias que generan ese riesgo.

Además de indicar el tipo de tratamiento, es necesario describir brevemente las acciones a llevar a cabo conforme al tratamiento. Por ejemplo:

[Base de datos de operaciones] [Alteración accidental de la información] [8] [Prevenir]

Para prevenir la alteración accidental de la información en la base de datos de operaciones, es crucial formar a los empleados, implementar validaciones en los datos, establecer controles de acceso, usar flujos de trabajo con revisiones previas y probar cambios en entornos de prueba antes de aplicarlos en producción.

Entrega

Se entregará, en cada sesión, una **memoria** de trabajo en **formato PDF** que incluya el contenido de las sesiones anteriores.

Todas las memorias deben incluir una portada con los datos de todos los miembros del equipo.

Al terminar la auditoría completa de la empresa virtual (Práctica 5), todos los grupos presentarán el trabajo realizado al resto de los compañeros.



Universidad de Jaén

Auditoría y Seguridad en Sistemas de Información

Módulo 2: Sesión 3

Mapa de Riesgos: Activos y Amenazas

Introducción

En este módulo vamos a realizar diferentes prácticas que nos lleven a simular una auditoría de una forma realista. Las prácticas se pueden realizar en grupos (recomiendo utilizar los mismos grupos de la parte teórica). Dado que no tenemos a nuestra disposición una empresa en la que realizar la auditoría, vamos a auditar una pequeña empresa virtual.

Vamos a utilizar como guía para realizar las tareas propuestas la metodología **MAGERIT** que contiene procedimientos para analizar y gestionar los riesgos de los sistemas de información. Fue desarrollada por el Consejo Superior de Administración Electrónica (CSAE) del Gobierno de España. En su versión 3, consta de tres libros donde se describe en detalle el procedimiento a seguir (los documentos se encuentran en PLATEA)

Objetivo

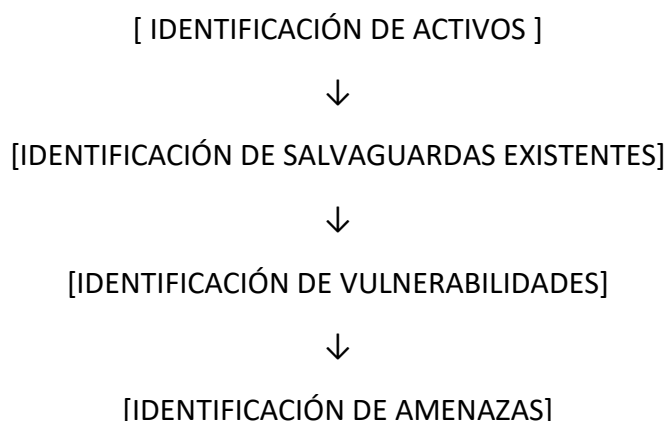
- Realizar las tareas iniciales del análisis de riesgos
- Identificar las salvaguardas y las amenazas asociadas a los activos, así como su nivel de debilidad o vulnerabilidad.
- Definir el mapa de riesgos

Entrega

- Se entregará en cada sesión una **memoria** de trabajo en formato PDF que incluirá el contenido de las sesiones anteriores.
- Todas las memorias deben incluir una portada con los datos de todos los miembros del equipo.

Descripción

En esta práctica partiremos de los datos de la empresa de las sesiones anteriores, así como de los activos identificados en la última práctica. Para realizar el análisis de riesgos en la auditoría, vamos a seguir el enfoque propuesto por las normas ISO 27001, 27002 y 27005, que consta de las siguientes fases:





[EVALUACIÓN Y TRATAMIENTO DEL RIESGO]



[PROPUESTA DE CONTROLES]

Asumiremos que, tras chequear el sistema de información (SI), hemos detectado vulnerabilidades que pueden ser aprovechadas por distintas amenazas para comprometerlo.

En esta sesión nos centraremos en **identificar salvaguardas, vulnerabilidades y amenazas detectadas y en función de todo lo anterior, cuantificar el nivel de debilidad o vulnerabilidad** que puede afectar a nuestros activos.

Para cada activo llevaremos a cabo las siguientes tareas:

1. **Identificación de salvaguardas (MAGERIT, Libro 1).** Identificaremos, si las hubiese, las salvaguardas existentes que limitarían la vulnerabilidad del sistema.
2. **Identificación de vulnerabilidades.** Listado de vulnerabilidades identificadas tras examinar el SI (p. ej.: software no actualizado, contraseñas débiles, centralización de recursos, ...).
3. **Listado de amenazas (MAGERIT, libro 2).** A partir del listado de vulnerabilidades anterior, crear una lista de amenazas identificadas para cada activo y valorarlas según su probabilidad de ocurrencia. La **probabilidad** será **baja, media o alta**. Ej: para un router, la probabilidad de un robo sería baja, de un incendio sería baja y de un hackeo sería media. Cuando se considere necesario, además de indicar las amenazas, también se pueden indicar las consecuencias para el sistema de información en caso de que se materialicen dichas amenazas.
4. **Evaluación de la debilidad o del nivel de vulnerabilidad de cada activo_amenaza.** Partiendo del conjunto de activos, para la terna (activo, amenaza y probabilidad) valorar la **debilidad** del activo ante esa amenaza, usando los valores **bajo, medio o alto**, teniendo en cuenta las salvaguardas. Ej: El nivel de vulnerabilidad de un router ante un hackeo partiendo de una probabilidad alta, podría ser bajo si el tráfico de red está monitorizado en tiempo real o alto si no se monitoriza. Para la amenaza de incendio con probabilidad baja, la vulnerabilidad podría ser media si no se dispone de medidas contra incendios, o baja en caso contrario.



Universidad de Jaén

Auditoría y Seguridad en Sistemas de Información

Módulo 2: Sesión 2

Activos de información

Introducción

En este módulo vamos a realizar diferentes prácticas que nos lleven a simular una auditoría de una forma realista. Las prácticas se pueden realizar en grupos (recomiendo utilizar los mismos grupos de la parte teórica). Ya que no tenemos a nuestra disposición una empresa donde realizar la auditoría, vamos a auditar una pequeña empresa virtual.

Objetivo

- Identificación de los **activos de información**.

Entrega

- Se entregará en cada sesión una **memoria** de trabajo con **formato PDF** donde se incluirá el contenido de las sesiones anteriores.
- Todas las memorias deben contener una portada con los datos de todos los miembros del equipo.

Descripción

En esta sesión partiremos de la empresa descrita en la práctica anterior. Una vez definido el contexto organizacional y operacional, en esta sesión nos centraremos en **identificar todos los activos del sistema de información** de la empresa y en su clasificación.



Para facilitar la identificación de los activos, los vamos a clasificar en tres grupos:

- **Datos e información:** se incluirá toda la documentación o información que tenga valor dentro de la empresa (datos de los clientes, datos de proveedores, etc.).
- **Sistemas e infraestructura:** todos los equipos y aplicaciones que quieran incluirse dentro del esquema de seguridad (equipos informáticos, móviles, aplicaciones con licencia, etc.).
- **Personal:** se deben incluir todo el personal de la empresa que pueda suponer un riesgo de seguridad (director, administrador del sistema, empleados con acceso a equipos informáticos, etc.). Como varios usuarios comparten roles, se sugiere asignar un nombre o usuario para identificar de forma independiente a cada miembro del esquema de seguridad. Ej.: Pedro García (administrador del sistema), Ana Ortega (administradora del sistema).

Una vez identificados los activos, clasificar y valorar cada uno de ellos para dejar clara su importancia dentro del esquema de seguridad. Para ello se elaborarán 3 tablas similares a las siguientes:

	Clasificación			Magnitud del daño			
Datos e Información	Confidencial, privado o sensitivo	Obligación por ley, contrato o convenio	Costo de recuperación (tiempo, económico, material, emocional)	Insignificante (Ninguno)	Bajo	Medio	Alto
Contactos							

	Clasificación			Magnitud del daño			
Sistemas e infraestructuras	Acceso exclusivo	Acceso ilimitado	Costo de recuperación (tiempo, económico, material, emocional)	Insignificante (Ninguno)	Bajo	Medio	Alto
Portatil							

	Clasificación			Magnitud del daño			
Personal	Perfil alto (indispensable para el funcionamiento)	Perfil medio (experto en su área)	Perfil bajo (no indispensable)	Insignificante (Ninguno)	Bajo	Medio	Alto
Administrador SI							

Para rellenar las tablas se deben tener en cuenta las siguientes consideraciones:

- En la columna **Clasificación**, marcar con una 'X', una o varias opciones que corresponden a la lista de activos (cuando no aplique para su caso, las casillas pueden dejarse en blanco)
- En la columna **Magnitud de Daño**, marcar con una 'X', la magnitud de daño que puede sufrir el activo, como consecuencia de un impacto causado por un ataque exitoso. Para cuantificar el nivel del daño, hay que tener en cuenta las siguientes posibilidades (y otras que se os ocurran):
 - se pierde la información/conocimiento,
 - terceros podrían tener acceso a la información/conocimiento,
 - la información ha sido manipulada o está incompleta,
 - la información/conocimiento o persona no está disponible,
 - hay dudas acerca de la legitimidad de la fuente de la información,
 - desastres naturales o accidentales y
 - fallos energéticos.

Para cuantificar el nivel de daño de los elementos de información, se considera la siguiente escala:

- Insignificante: No causa ningún daño a la organización o su impacto es mínimo.
- Bajo: Causa daño aislado, que no perjudica a ningún activo.
- Medio: Provoca la pérdida de algún activo. Si no se atiende a tiempo, a medio o largo plazo puede provocar daños a la organización.
- Alto: A corto plazo, provoca daños a la organización.
- Muy alto: Daño muy importante y debe atenderse lo antes posible.



Universidad de Jaén

Auditoría y Seguridad en Sistemas de Información

Práctica Sesión 6

**Entorno operacional, organizacional y
alcance**

Introducción

En este módulo vamos a realizar diversas prácticas para intentar simular una auditoría de forma realista. Las prácticas pueden realizarse en grupos (recomiendo utilizar los mismos grupos que en la parte teórica). Ya que no tenemos a nuestra disposición una empresa real en la que realizar la auditoría, vamos a auditar una pequeña empresa ficticia. Esta práctica se realizará en 5 sesiones de forma incremental; es decir, en cada sesión se añadirá nuevo contenido a la sesión anterior. **Tras completar la auditoría de la empresa ficticia (Práctica 5), todos los grupos presentarán el trabajo realizado al resto de los compañeros.**

En esta sesión nos centraremos en:

Objetivo

- Se determinará el **entorno operacional y organizacional** de la empresa y se fijará el **alcance** de la auditoría.

Entrega

- Se entregará en cada sesión una **memoria** de trabajo con **formato PDF** donde se incluirá el contenido de las sesiones anteriores.
- Todas las memorias deben contener una portada con los datos de todos los miembros del equipo.

Descripción de la empresa¹

CRP Computers es una empresa de mediano tamaño (PYME) que, preocupada por posibles fallos de seguridad, os ha contratado para que realicéis una auditoría informática de su empresa. Aunque cuenta con algunas medidas de seguridad y control, no está seguro de si estas funcionan correctamente y desea mejorar la seguridad de sus activos. Para ello, os proporciona la siguiente información.

Es una empresa de tamaño mediano dedicada al montaje y venta de equipos y componentes informáticos con sede en la siguiente dirección: Polígono Industrial Los Olivares, C. Escañuela, 19, 23009 Jaén. Además de la atención al público en su sede principal, dispone de un servicio de venta online que supone el 35% de los ingresos totales.

Dispone de una única nave industrial en la que lleva a cabo su actividad. Esta nave industrial tiene unas dimensiones de 10 metros de fachada por 20 metros de profundidad y consta de dos plantas. En la planta superior se encuentran las oficinas donde se realiza la actividad comercial (es la más grande), la oficina del director ejecutivo, una sala de reuniones y los

¹ Al ser una descripción inventada, ésta es susceptible de ser ampliada con otros aspectos que consideréis oportunos e interesantes, con el objetivo de hacer más realista la auditoría. Estas mejoras serán consideradas en la evaluación de la práctica.

servicios. En la planta inferior hay una sala para los servidores, una pequeña zona de exposición y venta al público, una sala pequeña con cafetera y microondas que se puede utilizar como espacio de recreo o para almorzar, servicios y un almacén/taller donde se almacenan los componentes, se montan y se reparan los equipos.

CRP Computers atiende a los clientes de lunes a viernes en horario de 10:00 a 14:00 y de 17:00 a 20:00. El sábado, el horario es de 10:00 a 14:00. La tienda on-line recibe peticiones las 24 horas del día, los 7 días de la semana, pero los pedidos on-line se procesan y envían en horario laboral.

A nivel de personal, la empresa cuenta con dos administradores encargados de todos los aspectos relacionados con el servicio de informática, un jefe de almacén, dos trabajadores de almacén, un jefe de taller, tres trabajadores que montan y reparan equipos, un dependiente de atención al público, un jefe de compras, un administrativo y el director ejecutivo de la empresa.

Todos los trabajadores tienen a su disposición un ordenador con 16 GB de RAM, 1 disco duro de 512GB SSD y un procesador Intel i5 11ª gen. 2.6 GHz 8 núcleos, con tecnología turbo boost hasta 4.1 GHz. El sistema operativo es Windows 10 y el antivirus Panda Advanced. Disponen de un único servidor físico que centraliza todos los servicios.

Todos los equipos están conectados a una red inalámbrica WIFI que se conecta a internet mediante una conexión de fibra óptica de 600 MB simétricos proporcionada por DIGI.

El promedio de cortes de suministro eléctrico en la zona es de 5 cortes al año con una duración media estimada de 25 minutos.

CRP Computers tiene registrados 3500 clientes. El promedio de compras en un día es de 32, por un importe total de 5.525 €. Cada día reparan una media de 10 equipos informáticos por un valor medio de 150€.